

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1	Scope	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
2	Normative References	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
3	Terms & Definitions	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
4	Risk assessment concepts	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
4.1	Purpose and benefits	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
4.2	Risk assessment and the risk management framework	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
4.3	Risk assessment and the risk management process	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
4.3.1	General	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
4.3.1	General	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	8	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Business As Usual (BAU) Security, Compliance & Resilience Practices	GOV-14	Mechanisms exist to incorporate security, compliance and resilience principles into Business As Usual (BAU) practices through executive leadership involvement.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	8	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	
4.3.2	Communication and consultation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
4.3.3	Establishing the context	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	10	
4.3.3	Establishing the context	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	8	
4.3.3	Establishing the context	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Threshold	RSK-01.4	Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.	8	
4.3.3	Establishing the context	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	8	
4.3.3(a)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	10	
4.3.3(b)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	10	
4.3.3(c)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	10	
4.3.4	Risk assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	8	
4.3.4	Risk assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	8	
4.3.5	Risk treatment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.3.5	Risk treatment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Response	RSK-06.1	Mechanisms exist to ensure proper risk response actions were performed to remediate findings from security, compliance and/or	8	
4.3.5	Risk treatment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	8	
4.3.5	Risk treatment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to develop appropriate risk treatment options, based on applicable risk assessment findings, including:	8	
4.3.5	Risk treatment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to involve a risk treatment team (RTT) and applicable stakeholders will utilize to remediate identified risks	8	
4.3.6	Monitoring and review	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	8	
4.3.6	Monitoring and review	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan or Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum:	8	
4.3.6	Monitoring and review	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	8	
5	Risk assessment process	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
5.1	Overview	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized	10	
5.2	Risk identification	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	10	
5.3	Risk analysis	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
5.3.1	General	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized	10	
5.3.2	Controls assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	8	
5.3.2	Controls assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	
5.3.2	Controls assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly,	5	
5.3.3	Consequence analysis	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service provider, etc.); or	5	
5.3.3	Consequence analysis	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to involve a risk treatment team (RTT) and applicable stakeholders will utilize to remediate identified risks	5	
5.3.4	Likelihood analysis and probability estimation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the	10	
5.3.4(a)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.3.4(b)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.3.4(c)	N/A	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.3.5	Preliminary analysis	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.3.6	Uncertainties and sensitivities	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.4	Risk evaluation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.5	Documentation	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	
5.6	Monitoring and reviewing risk assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Non-Compliance Oversight	CPL-01.1	Mechanisms exist to document and review instances of non-compliance with statutory, regulatory and/or contractual obligations to develop appropriate risk mitigation actions.	8	
5.6	Monitoring and reviewing risk assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan or Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum:	8	
5.6	Monitoring and reviewing risk assessment	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	8	
5.7	Application of risk assessment during life cycle phases	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are	10	
6	Selection of risk assessment techniques	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
6.1	General	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	No Relationship	N/A	N/A	N/A	0	
6.2	Selection of techniques	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure,	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **ISO/IEC 31010:2019 - Risk management - Risk assessment techniques**

Focal Document URL: <https://www.iso.org/standard/72140.html>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-general-iso-31010-2009.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.3	Availability of resources	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to assess all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRCP) and document all exceptions	5	
6.3	Availability of resources	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	5	
6.3	Availability of resources	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Management Resourcing	RSK-01.2	Mechanisms exist to reduce the magnitude or likelihood of potential impacts by resourcing the capability required to manage technology-related risks.	5	
6.4	The nature and degree of uncertainty	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Framing	RSK-01.1	(1) Assumptions affecting risk assessments, risk response and risk monitoring; Mechanisms exist to identify:	5	
6.5	Complexity	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	
6.6	Application of risk assessment during life cycle phases	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	10	
6.7	Types of risk assessment techniques	For specific requirement details, buy a licensed copy of the Focal Document at: https://www.iso.org/standard/72140.html	Functional	Subset Of	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	10	